

AI Security 1.5. AI Forensics

Task 1 - Introduction

The world of Digital Forensics is full of pieces needing to be connected, often under a time constraint. This can be a challenging task, but one that many forensics analysts have accomplished without the need for AI tools. This begs the question: Does the digital forensics industry need the AI tools being used by so many other adjacent industries? This room aims to answer this question, exploring the potential application of AI in digital forensics, the challenges that come with that and the potential ethical and legal implications.

Learning Objectives

- Understand the day-to-day challenges faced in DFIR
- Understand how AI can be used to address those challenges
- Understand the challenges that arise when you use AI for forensics investigations and the ethical/legal implications this has
- Understand how AI impacts the DFIR investigation process

Task 2 - The AI Forensics Landscape

- **Data Processing:** The field of Digital Forensics is one ripe with tasks requiring the investigator/analyst to process vast amounts of data in search of evidence or environmental clues. This data processing can be a massive undertaking for an investigator and requires a lot of manual work and time. Now armed with the power of parallelised deep learning & Transformer models, which can process entire bodies of text in parallel (often in mere milliseconds), providing insights and classifications on the processed data.
- **Anomaly Detection:** Analysts are tasked with identifying attacks, and this can often be a “needle in a haystack” scenario, especially sophisticated attacks which can (and often are designed to) blend in with normal activity. Machine Learning algorithms can learn what “normal” behaviour looks like for users, systems and networks, allowing supervised and unsupervised models to identify potential anomalies that could indicate malicious behaviour. Turning the haystack into a handful of hay. This ability to recognise patterns on such a large scale can also mean patterns are spotted that humans can't comprehend.
- **Scalability:** Modern infrastructures can take many different forms, such as cloud, hybrid, remote endpoints, etc., generating more forensic data than ever. systems can scale effortlessly, continually processing and learning from millions of events across these large and distributed environments, enabling teams to cover more ground without a proportional increase in workload.

AI in the Wild

DFIR Task	What AI/ML Enables	Example Tools / Platforms	How AI Solves It
Anomaly Detection / UEBA	Flags unusual user/system behavior compared to learned “normal”	Splunk UEBA(opens in new tab) , Elastic ML(opens in new tab) , Exabeam(opens in new tab)	AI uses unsupervised learning techniques (like Isolation Forests and Autoencoders) to learn baseline behaviour for users and systems. Deviations from this baseline are flagged as potential threats, even without predefined rules.
Phishing & Communication	Detects phishing emails and flags risky language in chat/email logs	Microsoft Defender for O365(opens in new tab) , Splunk NLP(opens in new tab)	Transformer-based language models (e.g., BERT, RoBERTa) classify messages as phishing or benign based on tone, structure, and known attack patterns. These models help detect impersonation, urgency phrases, and malicious links.
Malware / File Classification	Classifies files as malicious or benign based on	Microsoft Defender (STAMINA)(opens in new tab) , Cylance(opens in new tab)	AI systems analyse file metadata, code signatures, and sandbox behaviour to detect threats. These models are trained

	extracted static/dynamic features	tab), VirusTotal ML integrations(opens in new tab) .	on large malware corpora to classify new files based on patterns learned from known threats.
Alert Triage & Prioritisation	Automatically scores, ranks, and filters alerts to reduce analyst workload	Cortex XSOAR/XSIAM(opens in new tab) , IBM QRadar Advisor(opens in new tab) , CrowdStrike Falcon + Charlotte AI(opens in new tab) .	AI analyses past alert data, analyst feedback, and incident outcomes to rank alerts by severity and relevance. This reduces noise and surfaces the most urgent issues first, saving analysts time, a valuable resource in DFIR.
Timeline & Event Correlation	Reconstructs attack timelines by clustering and linking logs across sources	Timesketch(opens in new tab) , Velociraptor(opens in new tab) , Jupyter-based analysis(opens in new tab) .	AI clusters similar log events, identifies causal relationships, and aligns activity across systems. This helps analysts visualise attack chains and reconstruct incident timelines faster. Again, time is a valuable resource , and one of the key benefits of integrating AI into DFIR.

AI Limitations

AI systems and modern machine learning models are generally *probabilistic*; instead of following a fixed ruleset that provides a fixed outcome, they use statistical models to learn from data and make predictions with certain possibilities. It's why you rarely get the same output when you ask AI a query unless you have customised your settings to make it more deterministic.



Important metrics to consider when evaluating AI performance are:

- **Accuracy:** Accuracy refers to the overall rate of correct predictions. It's very important when assessing an AI 's performance to not only consider accuracy, as in isolation, it can be very misleading. Especially in a field such as digital forensics, where we often deal with highly imbalanced data (a few malicious files amongst thousands of benign ones, etc.), so a model can achieve a high accuracy by simply predicting the majority class each time.
- **Precision:** Precision measures how often a model's positive predictions are correct. In other words, out of all of the files flagged as malicious, how many are actually malicious? Higher precision = fewer false positives (saving time chasing down irrelevant leads). However, this metric also suffers in isolation as the model can choose to be very selective, only flagging the very obvious malicious files, meaning some malicious files may be missed.
- **Recall:** Recall measures how successful the model was in identifying all positives in the provided dataset. e.g. identifying 18 out of 20 malicious files present would result in a 90% recall. Again, in isolation, this metric would be ineffective as a model could simply cast a wide net, flagging every file as malicious, achieving 100% recall but flagging many false positives in the process.

The GIGO (Garbage In, Garbage Out) principle is just as true for AI systems (if not more) than it is for any system. In other words, the quality of an AI's output is directly determined by the quality of its input. This means if an AI has been trained on "bad" data, that is, data that doesn't accurately capture the scope of what is being learned and understood by the model, it will lead to the model confidently asserting false predictions as though they were fact. When using this technology to pursue justice, you can see why this calls for extra caution.

In conclusion, while AI offers powerful capabilities in DFIR, it's not a silver bullet. Its non-determinism, evaluation challenges, and performance trade-offs mean it should never replace human expertise. AI can accelerate and enhance our work, but human oversight, judgment, and validation will always remain essential. In other words, AI cannot replace humans as digital forensic analysts.

| What ability of AI helps turn a DFIR investigator by recognising patterns they might not have been able to comprehend?

Anomaly Detection

| Which metric tells you the proportion of positively flagged results that were actually correct?

Precision

| What term describes the AI characteristic where the same input may yield different outputs across different runs?

non-determinism

Task 3 - AI & DFIR

Digital image and video forensics is an excellent example of AI/ML and its capabilities, making our lives in DFIR easier. One way in which it does this is through CNN (convolutional neural networks). A CNN is a type of neural network that automatically learns patterns in data using small filters commonly used for images. However, it can also be applied to other types of data like audio, time series, or text where spatial or sequential patterns are important. Examples of how this can be used in the field include:

- **CNN Based Forgery Detection:** Researchers have started combining traditional forensics methods such as ELA (Error Level Analysis, a technique used in image forensics to detect areas of an image that may have been digitally altered) with models to identify image tampering.
- **Deepfake Detection:** The advancement of technologies has also meant advancements for the attacker. Deepfakes are one area which has seen a dramatic increase in quality, and as a forensics analyst, this is yet another area where new challenges are presented.
- **GANs:** Another exciting development in image and video forensics is the use of Generative Adversarial Networks (GANs), a setup where two neural networks compete: one generates fake media, and the other tries to detect it.

Communication Analysis: Communication analysis (and other areas of DFIR, for that matter) involves the processing and analysis of large volumes of text.

- **Phishing Email Detection:** Transformer-based models that are trained for NLP (Natural Language Processing), such as and RoBERTa, excel at identifying emails. This technology not only means we can move away from a rule-based approach for detecting incoming emails (which looked for known bad URLs or keywords) and adopt deep learning, context-aware models but also means it can be used to categorise emails for **human review**, saving a lot of time.
- **Chat Log and Social Media Analysis:** The same technology mentioned above is also harnessed by some forensic platforms, allowing forensic investigators to automatically scan chats for keywords or patterns related to threats (like discussing of nefarious plans) and perform **sentiment analysis** to gauge emotional tone.

Timeline Reconstruction and User Behavior: Reconstructing incident timelines is a common and critical part of an investigation; it is also a very labour-intensive and time-consuming task. Machine learning is now being harnessed to help us with this task:

- **Automated Event Timeline Reconstruction:** systems are particularly adept at correlating **time-sequenced** data from multiple sources and putting together what happened before, during, and after an incident. For example, algorithms

can ingest logs, filesystem timestamps, network records, etc., and automatically build a chronological timeline of events or merge events from server logs, alerts and application logs into a unified timeline.

- **Anomaly Detection:** is incredibly good at identifying patterns. In , this ability can give you an eagle eye, flagging things like impossible logins, where a user was logged in at two places simultaneously, or behaviour unusual for this specific user.

Malware Detection/Analysis: AI/ML has also lent itself greatly to the area of Malware detection and analysis, with research into this subject looking to provide an edge over traditional analysis methods and signature-based detection:

- Breakthroughs in being able to represent malware files in ways processible by deep neural networks have made it possible to **classify a file** as malicious or benign (e.g. [Microsoft and Intel's STAMINA project](#)(opens in new tab)).
- ML is also being considered for use in **Dynamic Analysis**, observing how a program behaves to identify whether it is malicious or not.
- Using some form of / is now very common in antivirus and endpoint detection response products.

AI and machine learning are not just theoretical tools. They are actively reshaping how digital forensic investigators approach complex, time-sensitive, and data-heavy challenges. Whether it's detecting tampered images using CNNs, identifying phishing emails with advanced NLP models, or reconstructing incident timelines from fragmented data, AI/ML technologies are accelerating analysis, aiding detection, and making it possible to uncover patterns that might otherwise go unnoticed. While these tools don't replace human expertise, they significantly enhance it, allowing analysts to work smarter and respond faster.

What type of neural network is commonly used in image and video forensics due to its ability to learn spatial patterns in visual data?

Convolutional Neural Network

What kind of analysis can be performed on social media or chat logs to assess the emotional tone of messages?

Sentiment Analysis

What type of data do AI systems correlate to reconstruct the timeline of an incident automatically?

Time-Sequenced

What type of analysis observes how a program behaves to determine whether it is malicious, e.g., using its API call sequence?

Dynamic Analysis

Task 4 - AI Legal & Ethical Implications

Artificial intelligence is increasingly being woven into DFIR, enabling investigators to save time collecting evidence, providing deep insights and integrating with tools which are already commonplace in the industry. While these advancements pose obvious benefits, they also raise complex legal and ethical questions. Courts and regulators worldwide are grappling with how AI-generated evidence fits into established evidentiary standards, and there are key issues that investigators need to consider when using AI in a DFIR context. In this task, we will explore these issues.

Explainability and Transparency: One of the core issues facing the implementation of AI in digital forensics is the explainability of AI tools. Many AI models are **"black boxes"**, meaning they don't readily explain how they came to a conclusion. This clashes with a core tenet of forensics analysis, the need for transparency and defensibility of evidence interpretation. the AI-generated evidence was excluded by the court. What we can learn from this event is that without explainability and expert validation, AI-generated insights may not survive a courtroom challenge, failing to meet admissibility standards like the **U.S. Daubert test** (a U.S. legal rule that determines the admissibility of expert testimony, particularly scientific testimony, in federal court), underscoring the sentiment that AI is NOT a replacement for human expertise but a guiding light.

Bias and Fairness: AI systems can unintentionally introduce bias, raising ethical and legal concerns about fairness and due process. ML models are trained on historical data; if that data contains skewed representations or prejudices, the model's

output will reflect them. In a forensics context, bias can influence what conclusions are drawn and evidence is prioritised, for example, de-prioritising non-English communications in a multilingual data set, delaying the examination of relevant evidence. A stark real-world example of this bias in action is **facial recognition** technology being used by police. Studies have found that these algorithms misidentify black and other minority individuals at much higher rates than white individuals. This algorithmic bias can translate into real-world injustice, with it being found that in the U.S., there are at least seven known wrongful arrests due to faulty face recognition[\(opens in new tab\)](#), and almost every one of these victims was an African American mistakenly identified by an AI. What this means is that:

1. Legally, if a defence can show a technique is biased, judges may exclude its results.
2. Ethically, forensic experts have a duty to validate and correct biases present in tools (for example, using diverse training data or bias mitigation techniques).

Accountability and Chain of Custody: In terms of trust and accountability, courts require that digital evidence be handled in a **traceable** and **preservable** manner and that integrity is preserved at each step. We achieve this by maintaining the **chain of custody** and an audit trail. Regarding AI-generated digital evidence, this can create conflicts as many AI tools (especially cloud-based services) operate opaquely, clashing with these requirements. AI processes must be **carefully documented and secured**, and using on-premises or controlled systems can help achieve this and satisfy legal scrutiny.

Privacy and Data Protection: Public cloud servers may inadvertently expose sensitive evidence to third-party servers, violating privacy laws or court orders. Legal frameworks like GDPR may restrict how personal data is processed, even for law enforcement purposes. So DFIR investigators face pressure to ensure AI is used in a privacy-preserving manner. This can be achieved, for example, by running AI tools in secure offline environments or using **federated learning**. These considerations cannot be understated in their importance as part of the ethical use of AI in forensics; as if AI systems use personal data without proper authority, any evidence gleaned might be ruled inadmissible.

The Verdict: This task has covered the many ethical and legal considerations that need to be made when using AI systems in a digital forensics context. While it is abundantly clear that AI can be a force of good, with its abilities enabling investigators to be more productive, efficient and effective than ever before in the pursuit of justice, it is also clear that this new tool needs to be wielded with a great amount of care. The classic Uncle Ben quote comes to mind: "With great power comes great responsibility", which is especially true when it comes to forensics in a legal and ethical context. Therefore, investigators have a responsibility/duty to ensure that they are using AI following the legal and ethical guidelines outlined above to ensure justice can be served in a fair and ethical manner.

| What legal test used in the U.S. assesses whether expert or scientific testimony is admissible in court?

Daubert

| What term describes AI models whose internal decision-making processes are difficult to interpret?

Black Box

| What real-world technology used by law enforcement has been shown to produce racially biased results in identifying suspects?

Facial Recognition

| What technique allows machine learning to be performed without transferring sensitive data to a central server, helping preserve privacy?

Federated Learning

Task 5 - Practical - The Digital Trail

Activated the virtual environment. As a forensic investigator, isolation is key; you'll be working in a virtual environment to ensure any tools you run or changes you make don't contaminate the original evidence. Think of it as your digital crime scene suit.

```
source /opt/dfir-env/bin/activate
python3 /opt/dfir-lab/classify_logs.py /var/log/auth.log
```

```
(dfir-env) ubuntu@tryhackme:~$ python3 /opt/dfir-lab/classify_logs.py /var/log/auth.log
Failed password for invalid user admin from 192.168.0.100 port 22 ssh2
Accepted password for j.morgan from 192.168.0.100 port 22 ssh2
```

```
python3 /opt/dfir-lab/file_anomalies.py
```

```
[*] Scanning paths:
```

- /opt/robbco
- /tmp
- /dev/shm
- /usr/local/bin

```
[!] Supervised AI-flagged suspicious files:
```

	path	size	entropy
0	/opt/robbco/sys/boot_monitor.log	59	4.535458
1	/opt/robbco/engineering/MFBootAgent/mfboot_main.c	97	5.122591
2	/opt/robbco/firmware/RETROS_BIOS/core.asm	54	4.358886
3	/tmp/dock-replace.log	235	4.820192
4	/tmp/.syncd	87	4.492156
5	/tmp/.x	52	4.411602
6	/tmp/invoice_dump.txt	709	4.653766
10	/dev/shm/.core_dump_2025.tgz.enc	369	5.766267
14	/usr/local/bin/sysmon	52	4.411602

Checked the directory above by one by with cat command

The command `source /opt/dfir-env/bin/activate` is used to activate a Python virtual environment named `dfir-env` located in the `/opt/` directory on **Linux**

The command `python3 /opt/dfir-lab/classify_logs.py` executes a Python script designed to **classify build logs** for software packages, specifically identifying error types such as missing dependencies, test failures, or syntax errors. `/var/log/auth.log` is the primary text file used by Debian-based Linux distributions (such as Ubuntu) to record security and authentication events.

```
ubuntu@tryhackme:~$ ls /home/
ubuntu@tryhackme:~$ vim python3 /opt/dfir-lab/file_anomalies.py
ubuntu@tryhackme:~$ ls -la /tmp/
ubuntu@tryhackme:~$ cat /tmp/invoice_dump.txt
ubuntu@tryhackme:~$ cat /tmp/.syncd
```

```
/home/j.morgan/ <Stores collected recon data>
ls Documents/Invoice
libreoffice Documents/Invoices/invoice.ods
```

```
cat .bash_history
```

```
sudo nano /home/r.house/.ssh/auth_keys
```

The command `cat /dev/shm/.core_dump_2025.tgz.enc` will attempt to read and display the contents of a file named `.core_dump_2025.tgz.enc` located in the `/dev/shm` directory.

- **Location:** `/dev/shm` is a **tmpfs** (temporary file storage filesystem) mounted on RAM, meaning the file exists in memory.
- **Content:** The `.tgz.enc` extension suggests the file is an **encrypted tarball**. If the file exists and the user has read permissions, `cat` will output its raw binary data to the terminal, which will appear as **garbled text** or non-printable characters.

- **Persistence:** Since `/dev/shm` is volatile, the file will be **lost** if the system reboots or if the tmpfs is unmounted.

```
cat /dev/shm/.core_dump_2025.tgz.enc
echo hash " ] base64 -d

base64 -d /dev/shm/.core_dump_2025.tgz.enc > /tmp/stolen.tar.gz

mkdir /tmp/stolen_source
tar -xzf /tmp/stolen.tar.gz -C /tmp/stolen_source
```

The command `tar -xzf /tmp/stolen.tar.gz -C /tmp/stolen_source` extracts the contents of the compressed archive `/tmp/stolen.tar.gz` into the directory `/tmp/stolen_source`.

- **x:** Extracts files from the archive.
- **z:** Decompresses the archive using gzip (required for `.tar.gz` files).
- **v:** Displays verbose output, listing the files as they are extracted.
- **f:** Specifies the archive file (`/tmp/stolen.tar.gz`).
- **C:** Changes to the specified directory (`/tmp/stolen_source`) before extracting.

Phase I: Initial Access

Artefact	Behaviour	Impact/Analysis	Explanation
<code>/tmp/invoice_dump.txt</code>	Stores collected recon data	Reveals prior SSH usage, usernames, and active sessions	Output of the macro's system recon. Provided the attacker insight into viable accounts and access paths.

Phase II: Tooling and Infrastructure

Artefact	Behaviour	Impact/Analysis	Explanation
<code>/tmp/.syncd</code>	Connects to <code>http://10.0.0.66/payload.sh</code> and executes it	Initiates second-stage download	First-stage dropper used to quietly retrieve additional malicious tooling.
<code>/tmp/.x</code>	Reverse shell stub	Establishes remote shell to <code>10.0.0.66:4444</code>	Gave the attacker live access under <code>j.morgan</code> 's user context. Likely deployed immediately after the phishing document was opened.

Phase III: Privilege Escalation

Artefact	Behaviour	Impact/Analysis	Explanation
<code>/home/j.morgan/.bash_history</code>	Reveals use of <code>sudo</code> to modify SSH keys	SSH key planted in <code>r.house</code> 's <code>authorized_keys</code>	Subtle privilege escalation — no exploits used. Demonstrates abuse of legitimate permissions for escalation.

Phase IV: Disguise and Persistence

Artefact	Behaviour	Impact/Analysis	Explanation
<code>/usr/local/bin/sysmon</code>	Outbound connection to <code>10.0.0.66:5555</code>	Reverse shell disguised as system monitoring tool	Persistence through deception — masks itself as a legitimate binary to evade detection.
<code>/opt/robbco/sys/boot_monitor.log</code>	Fake boot telemetry logs	Justifies <code>sysmon</code> 's presence	Fabricated log file used to support the ruse of a legitimate monitoring utility.

Phase V: Source Code Theft

Artefact	Behaviour	Impact/Analysis	Explanation
<code>/opt/robbco/engineering/MFBootAgent/mfboot_main.c/opt/robbco/firmware/RETROS_BIOS/core.asm</code>	Flagged by ML model	Not malicious, but classified as suspicious	AI flag — Ransomware

Artefact	Behaviour	Impact/Analysis	Ex
<code>/dev/shm/.core_dump_2025.tgz.enc</code>	Base64-encoded stolen archive	Exfiltration-ready package containing RobbCo IP	pr sc St sh — st lo de

1. At what time does the attacker successfully log in as j.morgan?
python3 /opt/dfir-lab/classify_logs.py /var/log/auth.log
Answer : 03:01:02
2. What attack method was used to gain initial access?
Answer : Phishing
3. Can you find the attacker's email address?
Answer : akeane@poseidonenergy.net
cat /home/j.morgan/Mail/inbox/email_invoice.eml
4. What command did the attacker run as j.morgan to gain access to the r.house account?
Answer : sudo nano /home/r.house/.ssh/authorized_keys
Analyze /tmp/invoice_dump.txt to get the answer
5. What is the full path of the archive used to steal RobbCo's source code?
Answer : /dev/shm/.core_dump_2025.tgz.enc

Task 6 - Conclusion

A Bright Light on the AI Forensics Landscape: Covered the undeniable potential AI has to help forensic analysts in the pursuit of justice. From understanding how intelligent systems can enhance our abilities to comprehending the responsibility that's placed on us when we use them to aid in our investigations, here's what we've covered in this lesson:

- How / enhances tasks like anomaly detection, analysis, and timeline reconstruction
- The strengths and limitations of models used in forensics (e.g. probabilistic behaviour, precision-recall trade-offs)
- The legal and ethical challenges introduces, including explainability, chain of custody, and fairness
- A hands-on case investigation where you worked alongside an assistant powered by scikit-learn to uncover a targeted breach at RobbCo

AI is not a replacement for human insight. In fact, human insight has never been more important than it is now, as the rapid adoption of these AI systems grows.